IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Entity-Level Controls

Objectives

Strategic planning and technology roadmaps
Performance indicators and metrics
Project approval and monitoring processes
Policies, standards, and procedures
Employee management
Asset and capacity management
System configuration change management

Effects of Entity-level controls

- Entity-level controls have a pervasive influence throughout an organization.
- If they are weak, inadequate, or nonexistent, they can produce
  - material weaknesses relating to an audit of internal control and
  - material misstatements in the financial statements of the company.
- Entity level controls may have a permeating effect on the other control components. E.g., if management demonstrates a poor attitude toward hiring, training and promotion, the chance of the accounting department having the ability to produce accurate financial statements is significantly reduced.

Entity-level controls

- Are pervasive across an organization.
- Set the overall "tone at the top" for the IT organization and provide governance of the entire IT environment.
- An entity-level control is not always consistently defined and will vary by organization, depending on how the IT environment is defined.
- If a critical IT process is centralized, it is a good candidate for an entity-level controls review.

Entity-level controls - Examples

- **Example 1**
- If an organization has one data center and one set of processes for executing these areas, so physical security, environmental controls, and system monitoring would qualify as entity-level controls because they are centralized and pervasive.

- **Example 2**
- Multiple decentralized data centers.
- (Controls in example1 are centralized now in this scenario)

More examples of entity level controls

- Communication and enforcement of integrity and ethical values
- Conservative attitude in managing business
- Organizational structure conducive to efficiency and effective communication
- Appropriate assignment of authority and responsibility
- Hiring, training and promotion policies
- Policies and procedures to prevent or detect fraud

Activity Level Controls

- Relate to a particular class of transactions, account balances or financial statement disclosures. Generally a business has 3-6 significant distinct business activities, including:

1. Sales/accounts receivable/revenue recognition/cash collection
2. Purchases/accounts payable/expenses/cash disbursements
3. Inventory
4. Debt/interest expense
5. Hiring/payroll

Revisiting Definitions

- **Internal control(IC):** The process that provides reasonable assurance about the achievement of an entity's objectives with regard to reliability of financial reporting, effectiveness and efficiency of operations, and compliance with applicable laws and regulations. IC has 2 components:
  - **Control environment**: Includes the governance and management functions and the attitudes, awareness and actions of those charged with governance and management concerning the entity's internal control and its importance in the entity.
  - **Control activities:** Those policies and procedures that help ensure that management directives are carried out. Control activities are a component of internal control.

Steps for Auditing Entity-Level Controls

- 1. Review the overall IT organization structure to ensure that it provides for clear assignment of authority and responsibility over IT operations and that it provides for adequate segregation of duties.
  - Review IT organization charts and ensure that they clearly indicate reporting structures.
    - CIO
    - Multiple CIOs and ->CEO
  - Review IT organization charts and charters and ensure that they clearly delineate areas of responsibility.
  - Evaluate the division of responsibilities within the IT organization to ensure that duties are segregated appropriately
- 2.

Step 1: basic general guidelines:

- IT personnel should not perform data entry
- Programmers and those performing run/maintain support for systems should not directly be able to modify production code, production data, or the job-scheduling structure.
- Programmers and those performing run/maintain support for systems should be separate from those performing IT operations support.
- An IT security organization should be responsible for setting policies and monitoring for compliance with those policies

Step 2 & 3

- 2. Review the IT strategic planning process and ensure that it aligns with business strategies. Evaluate the IT organization's processes for monitoring progress against the strategic plan.
  - Look evidence of strategic planning process within IT.
  - Review documented short- and long-term IT priorities.
- 3. Determine whether technology and application strategies and roadmaps exist, and evaluate processes for long-range technical planning.
  - Look for evidence that long-term technical planning (purchased applications and technologies)
  - IT understands the vendor's support ?
  - When versions of products will cease to be supported and Look for the plans for upgrading or replacing the products.

Steps 4

- 4.Review **performance indicators & measurements** for IT. Ensure that processes and metrics are approved by key stakeholders for measuring performance of day-to-day activities and for tracking performance against service-level agreements, budgets, and other operational requirements.
  - Review System uptime and response time
  - Review SLAs

Steps 5

- 5.Review the IT organization's **process for approving & prioritizing new projects**. Determine whether this process is adequate for ensuring that system acquisition and development projects cannot commence without approval. Ensure that management and **key stakeholders review project status, schedule, and budget periodically** throughout the life of significant projects.

Steps for Auditing Entity-Level Controls

- 6. **Evaluate standards** for governing the execution of IT projects and for ensuring the quality of products developed or acquired by the IT organization. Determine how these standards are communicated and enforced.
  - Review PM, Software Development standards. etc.
- 7. Ensure that **IT security policies** exist and provide adequate requirements for security of environment. Determine how those policies are communicated and how compliance is monitored and enforced.
  - Verify Adequate Policy Coverage
  - Verify Stakeholder Buy-in
  - Verify Processes Around the Policies

Steps for Auditing Entity-Level Controls

- 8. Review and evaluate risk-assessment processes in place for the IT organization.
  - Monitoring internal controls in the IT environment, including internal audits and self-assessments
  - Performing formal threat and risk assessments of critical data centers and systems
  - Performing periodic reviews of the strategic IT plans and technical roadmaps and assessing risks to the achievement of those plans
  - Monitoring compliance with IT security policies and other relevant IT policies

Steps for Auditing Entity-Level Controls

- 9. Review and evaluate processes for ensuring that IT employees at the company have the skills and knowledge necessary for performing their jobs.
  - Ensure that job descriptions exist for all IT positions
  - Review the IT organization's training policies
  - Review performance-review processes.

Steps for Auditing Entity-Level Controls

- 10. Review and evaluate policies and processes for assigning ownership of company data, classifying the data, protecting the data in accordance with their classification, and defining the data's life cycle.
  - Review the company's data classification policy.
  - Review framework for classifying that data based on its criticality
  - Review evidence that the data classification policy has been implemented.
  - Determine whether life-cycle information has been created for company data

Steps for Auditing Entity-Level Controls

- 11. Ensure that effective processes exist for complying with applicable laws and regulations that affect IT and for maintaining awareness of changes in the regulatory environment.
  - Look for "single point of contact" that is responsible for monitoring regulatory environment & its impact on IT.
  - Ensuring that the responsibility for complying with those rules has been explicitly assigned to the appropriate organization(s).
  - monitoring the regulatory environment for additions and changes that will affect the company
  - Review the processes used to monitor the regulatory environment and evaluate their effectiveness.

Steps for Auditing Entity-Level Controls

- 11. Ensure that effective processes exist for complying with applicable laws and regulations that affect IT and for maintaining awareness of changes in the regulatory environment.
  - Obtain a list of IT-applicable regulations that have been identified, and look for evidence that responsibility for compliance with those regulations has been assigned and is being monitored.

Steps for Auditing Entity-Level Controls

- 12. Review and evaluate processes for ensuring that end users of the IT environment can report problems, are appropriately involved in IT decisions, and are satisfied with the services provided by IT.
  - Ensure that a help desk function provides end users with the ability to report problems.
  - Ensure that a process exists for obtaining end-user feedback after tickets are closed.
  - To ensure that the help desk does not seek customer satisfaction at the expense of security, review policies and processes for obtaining proper approvals prior to responding to user requests for having passwords reset and for obtaining system access.

Steps for Auditing Entity-Level Controls

- 13. Review and evaluate processes for managing third-party services, ensuring that their roles and responsibilities are clearly defined and monitoring their performance.

Steps for Auditing Entity-Level Controls

- 14. Review and evaluate processes for controlling nonemployee logical access.

Steps for Auditing Entity-Level Controls

- 15. Review and evaluate processes for ensuring that the company is in compliance with applicable software licenses.
- 16. Review and evaluate controls over remote access into the company's network (such as dial-up, VPN, dedicated external connections).
- 17. Ensure that hiring and termination procedures are clear and comprehensive.
- 18. Review and evaluate policies and procedures for controlling the procurement and movement of hardware.

Steps for Auditing Entity-Level Controls

- 19. Ensure that system configurations are controlled with change management to avoid unnecessary system outages.
- 20. Ensure that media transportation, storage, reuse, and disposal are addressed adequately by company-wide policies and procedures.
- 21. Verify that capacity monitoring and planning are addressed adequately by company policies and procedures.
- 22. Based on the structure of your company's IT organization and processes, identify and audit other entity-level IT processes.

Master Checklist

Auditing Entity-Level Controls

Checklist for Auditing Entity-Level Controls	
❑	1. Review the overall IT organization structure to ensure that it provides for clear assignment of authority and responsibility over IT operations and that it provides for adequate segregation of duties.
❑	2. Review the IT strategic planning process to ensure that it aligns with business strategies. Evaluate the IT organization's processes for monitoring progress against the strategic plan.
❑	3. Determine whether technology and application strategies and roadmaps exist, and evaluate processes for long-range technical planning.
❑	4. Review performance indicators and measurements for IT. Ensure that processes and metrics are in place (and approved by key stakeholders) for measuring performance of day-to-day activities and for tracking performance against SLAs, budgets, and other operational requirements.
❑	5. Review the IT organization's process for approving and prioritizing new projects. Determine whether this process is adequate for ensuring that system acquisition and development projects cannot commence without approval. Ensure that management and key stakeholders review project status, schedule, and budget periodically throughout the life of significant projects.
❑	6. Evaluate standards for governing the execution of IT projects and for ensuring the quality of products developed or acquired by the IT organization. Determine how these standards are communicated and enforced.
❑	7. Ensure that IT security policies exist and provide adequate requirements for the security of the environment. Determine how those policies are communicated and how compliance is monitored and enforced.
❑	8. Review and evaluate risk-assessment processes in place for the IT organization.
❑	9. Review and evaluate processes for ensuring that IT employees at the company have the skills and knowledge necessary for performing their jobs.

Master Checklist

Checklist for Auditing Entity-Level Controls *(continued)*	
❑	10. Review and evaluate policies and processes for assigning ownership of company data, classifying the data, protecting the data in accordance with their classification, and defining the data's life cycle.
❑	11. Ensure that effective processes exist for complying with applicable laws and regulations that affect IT (such as HIPAA, Sarbanes-Oxley) and for maintaining awareness of changes in the regulatory environment.
❑	12. Review and evaluate processes for ensuring that end users of the IT environment have the ability to report problems, are appropriately involved in IT decisions, and are satisfied with the services provided by IT.
❑	13. Review and evaluate processes for managing third-party services, ensuring that their roles and responsibilities are clearly defined and monitoring their performance.
❑	14. Review and evaluate processes for controlling nonemployee logical access.
❑	15. Review and evaluate processes for ensuring that the company is in compliance with applicable software licenses.
❑	16. Review and evaluate controls over remote access into the company's network (such as dial-up, VPN, dedicated external connections).
❑	17. Ensure that hiring and termination procedures are clear and comprehensive.
❑	18. Review and evaluate policies and procedures for controlling the procurement and movement of hardware.
❑	19. Ensure that system configurations are controlled with change management to avoid unnecessary system outages.
❑	20. Ensure that media transportation, storage, reuse, and disposal are addressed adequately by company-wide policies and procedures.
❑	21. Verify that capacity monitoring and planning are addressed adequately by company policies and procedures.
❑	22. Based on the structure of your company's IT organization and processes, identify and audit other entity-level IT processes.